

Software Engineering

Risk Mitigation Plan: Memento

Authors:

Kanan Badalov
Tunjay Huseynov
Tural Velizade
Mahammad Aliyev
Aykhan Manafov

Riga 2026

Table of Contents

Table of Contents

1. Introduction
2. Risk Assessment Scales
 - 2.1. Likelihood Scale
 - 2.2. Severity Scale
3. Risk Summary Matrix
4. Detailed Risk Analysis and Mitigation
 - 4.1. Security
 - 4.2. Privacy / Legal
 - 4.3. Technical
 - 4.4. Operational
 - 4.5. Business
5. Risk Priority Matrix
6. Mitigation Roadmap
7. Conclusion

1. Introduction

This document constitutes the Risk Mitigation Plan for the Momento mobile application, a location-based digital time capsule platform. It identifies and analyzes 15 key risks spanning security vulnerabilities, privacy and legal obligations, technical constraints, operational challenges, and business viability concerns.

Each risk is assessed using a five-level likelihood scale and a four-level severity scale. For each risk, the plan provides a description of its potential impact and a set of concrete, actionable prevention measures aligned with the project's technology stack.

This document is intended for the development team, project evaluators, and any stakeholders responsible for launch readiness decisions. It should be read in conjunction with the System Requirements Specification and the Security Vulnerability Analysis.

2. Risk Assessment Scales

All risks in this plan are assessed using the following standardized scales.

2.1. Likelihood Scale

Level	Definition
Impossible	Cannot occur under any foreseeable circumstances given the architecture and deployment environment.
Negligible	Theoretically possible but has no recorded precedent in comparable systems and is highly unlikely to materialize.
Rare	Could occur but has a low probability; not expected under normal operating conditions. May have happened in similar systems.
Possible	Has occurred in similar systems and may recur. Should be actively monitored and mitigated.
Very Likely	Has occurred repeatedly in comparable platforms or is inherent to the application design. Will almost certainly occur without mitigation.

2.2. Severity Scale

Level	Definition
Low	Minimal impact; easily corrected with no significant disruption to users or operations.
Medium	Noticeable impact on user experience, performance, or operational cost. Requires planned remediation.
High	Significant disruption to functionality, user trust, or legal compliance. Must be addressed before or shortly after launch.
Critical	Fundamental threat to the application's core value proposition, user safety, or legal standing. Must be resolved before any public release.

3. Risk Summary Matrix

The table below lists all 15 identified risks with their assigned likelihood and severity assessments.

ID	Risk Title	Category	Likelihood	Severity
R01	GPS Spoofing / Location Forgery	Security	Possible	Critical

ID	Risk Title	Category	Likelihood	Severity
R02	Insecure Direct Object Reference (IDOR) on Capsule Content	Security	Possible	Critical
R03	Session Token Theft / JWT Vulnerabilities	Security	Rare	Critical
R04	Push Notification Content Leakage via FCM	Security	Possible	Medium
R05	Excessive Location Data Retention	Privacy / Legal	Possible	Critical
R06	GDPR / Data Protection Non-Compliance	Privacy / Legal	Rare	High
R07	Mass Assignment / SQL Injection	Technical	Rare	High
R08	GPS Accuracy / Indoor Location Failure	Technical	Very Likely	Medium
R09	Excessive Battery Drain from Continuous GPS	Technical	Very Likely	Medium
R10	Cloud Storage Cost Overrun	Technical	Possible	Medium
R11	PostGIS Geospatial Query Performance	Technical	Rare	High
R12	Inappropriate / Illegal User-Generated Content	Operational	Possible	High
R13	Capsule Spam / Low-Quality Content	Operational	Possible	Medium
R14	Insufficient Critical Mass of Users	Business	Possible	High
R15	Firebase / Third-Party Service Outage	Business	Rare	High

4. Detailed Risk Analysis and Mitigation

The following subsections present each risk in full detail, organized by category. Each entry specifies the potential impact and concrete prevention measures tailored to the Momento technology stack.

4.1. Security

R01	GPS Spoofing / Location Forgery	Possible	Sev: Critical
<i>Category: Security</i>			
Impact Someone could use fake GPS coordinates to trick the system into thinking they're somewhere they're not. That way, they could get into the capsules without actually being there in person. That just doesn't really fit with what the app is supposed to be about, it gets in the way of finding new things, and it lets too many unauthorized people get into the capsules. Even people who aren't supposed to can get to these capsules, which means they stick around longer.			
Prevention Measures • Cross-validate location information using server-side signals such as Wi-Fi triangulation and cell towers, where available. • Use anomaly detection for users who discover capsules at physically impossible speeds or locations. • Use Android SafetyNet and iOS DeviceCheck APIs for rooted/jailbroken devices with GPS mock applications. • Use rate limits for discovery events per user and time window.			

- Use logging and auditing of discovery patterns for statistical anomalies.

R02	Insecure Direct Object Reference (IDOR) on Capsule Content	Possible	Sev: Critical
<i>Category: Security</i>			
Impact Also, people who weren't supposed could still get to capsule stuff like pictures and voice recordings even if they weren't there. When an API response has direct links to media, anyone who gets their hands on the URL can just open the content right away, without needing to go through the usual process of finding it. This is a really big privacy problem. It pretty much goes against what the app was made for, which was to keep things secure.			
Prevention Measures • Never expose direct media URLs in API responses. Create short-lived signed URLs (e.g., AWS S3 pre-signed URLs, with a maximum 15-minute expiration time) after server-side proximity validation. • Always perform access control checks on the backend for each capsule of content request, checking user discovery records before generating a URL. • Make sure to use a private S3/Firebase for storing all your media, and don't make them publicly readable. • Make sure to write a lot of authorization tests for every part of the capsule API			

R03	Session Token Theft / JWT Vulnerabilities	Rare	Sev: Critical
<i>Category: Security</i>			
Impact By the session tokens, the attacker has the ability to completely control the account, as he/she is able to drop or delete the capsules, gain points, and even access all the personal information of the victim. If the JWTs are not correctly configured, with the 'alg: none' algorithm accepted, the backend authorization is completely bypassed, and the attacker has the ability to see the location history of the victim as well as the personal media content.			
Prevention Measures • Validate JWTs server-side using Firebase's public key endpoint. Never trust unsigned or 'alg: none' JWTs. • Use small JWT exp times (e.g., 1 hour) with required refresh token rotation. • Use HTTPS for token transport. Require HSTS headers. • Use token revocation for logout and password change. • Use secure token storage (iOS Keychain, Android Keystore), never SharedPreferences or localStorage.			

R04	Push Notification Content Leakage via FCM	Possible	Sev: Medium
<i>Category: Security</i>			
Impact The push notifications with the capsule content or the exact location information are displayed on the lock screens of the device, which are accessible to anyone with physical access to the device. The FCM server keys in the source code allow the attacker to send arbitrary notifications to all the users of the app.			
Prevention Measures • Only opaque payloads should be used in the notification, e.g., "You have a new discovery!" but never capsule information, coordinates, or user information in the push notification payloads. • FCM server keys should be stored as environment variables, AWS Secrets Manager, Google Secret Manager, etc.; FCM server keys should not be stored in the mobile app bundle.			

- FCM server keys should be rotated periodically as well as in the case of suspected breach.
- FCM token refresh logic should be implemented, and the token should be invalidated during the logout process.

4.2. Privacy / Legal

R05	Excessive Location Data Retention	Possible	Sev: Critical
Category: Privacy / Legal			
Impact The system requires maintenance until the data needs to be deleted because it functions as continuous GPS tracking. A database breach would expose sensitive location history for all users, constituting a severe GDPR violation with financial penalties up to €20M or 4% of annual global turnover (GDPR Article 83). The data together with user profiles creates a possibility for criminal activities including stalking and physical violence.			
Prevention Measures • The system retains only GPS tracks of dropped capsules together with proximity test results because it does not maintain ongoing user location data. • The organization needs to implement data minimization through geohashing technology which uses H3 or S2 to create approximate region boundaries instead of providing specific location data. • The organization needs to protect all stored location information through AES-256 encryption while implementing column-level encryption of sensitive data fields in PostgreSQL databases. • The organization needs data retention policies which define data retention periods and require all location data to be deleted when an account gets deleted. • The organization needs to perform a GDPR Data Protection Impact Assessment (DPIA) before launching its public services.			

R06	GDPR / Data Protection Non-Compliance	Rare	Sev: High
Category: Privacy / Legal			
Impact The project faces three main risks because it processes personal data and location information without obtaining consent and fails to implement a proper privacy policy and data subject rights procedures which are required by EU regulations.			
Prevention Measure • The onboarding process needs to include explicit consent flows which will show customers the precise details of location data collection together with its purpose. • The organization needs to create a privacy policy that meets GDPR requirements before proceeding with their launch. • The organization must create account deletion capabilities together with data export options which include right of access and right to portability functions prior to launching their services. • An organization needs to assign a Data Protection Officer when their operations meet the requirements established by GDPR Article 37.			

4.3. Technical

R07	Mass Assignment / SQL Injection	Rare	Sev: High
<i>Category: Technical</i>			
Impact Malicious users can use specially designed payloads to control the capsule metadata which includes creator ID alteration and negative expiry setting and 1-per-24h restriction removal. The unvalidated GPS and text fields enable SQL injection attacks which can either expose or corrupt the complete PostgreSQL database. Attackers could claim ownership of other users' capsules or place capsules at arbitrary coordinates without physical presence.			
Prevention Measures - System designers should use Data Transfer Objects which define specific field access rights to control access to HTTP request data instead of binding database entities directly to incoming request data. - All input data must undergo server-side validation which includes checking GPS coordinate ranges and media MIME types and content size limits. - The system requires organizations to use parameterized queries and JPA/Hibernate ORM for database access while prohibiting them from using user input to build SQL strings. - The system must check and remove all XSS threats from text content which includes text capsule content that the application displays. - The system enforces the 24-hour duplicate coordinate rule by using a unique constraint at the database level which functions independently from application logic.			

R08	GPS Accuracy / Indoor Location Failure	Very Likely	Sev: Medium
<i>Category: Technical</i>			
Impact GPS systems provide outdoor accuracy that ranges between 3 meters and 15 meters but their performance decreases when used indoors or in areas with heavy building density. Users who stand at a capsule location encounter unlocking problems because of signal drift which leads to their frustration. This results in negative reviews and high early-stage churn.			
Prevention Measures - The system needs to implement a tunable proximity radius which users can adjust from its default setting of 30-50 meters without needing to update the application. - The system will use Wi-Fi triangulation and Bluetooth beacon fallback to provide better indoor positioning accuracy. - The user interface displays a real-time GPS accuracy meter which shows users when the signal strength drops below acceptable levels. - The system enables creators to choose their preferred discovery radius expansion option during the initial creation process of their capsule.			

R09	Excessive Battery Drain from Continuous GPS	Very Likely	Sev: Medium
<i>Category: Technical</i>			
Impact Continuous background GPS polling without interruption causes complete battery depletion for devices within a time frame of two to four hours. The users will disable location permissions and they will restrict background activity and they will uninstall the application which results in the complete destruction of the passive discovery system that provides Momento with its essential value.			

Prevention Measures

- The system requires users to use the significant-location-change API for iOS together with Fused Location Provider for Android instead of using continuous high-accuracy tracking.
- The system should activate high-accuracy GPS mode once the device enters a 500-meter radius from a known capsule cluster.
- The system needs to provide users with options to set background fetch intervals according to their preferences which can be scheduled for every 5 minutes outside of capsule zones.
- The system needs to show a battery impact warning during onboarding processes and when users access location permission dialogs.

R10 Cloud Storage Cost Overrun**Possible****Sev: Medium***Category: Technical***Impact**

Uncontrolled media uploads (photos, voice notes) may cause the cost of using AWS S3/Firebase Storage to get completely out of hand as the user base grows. Unused media from deleted capsules may quietly accumulate. Without billing controls, a viral growth spurt may cause costs to exceed the project budget.

Prevention Measures

- Impose file size constraints for each capsule: photos < 5MB, voice notes < 2MB.
- Compress media before upload using suitable codecs.
- Schedule auto-deletion of unused media from cloud storage after capsule removal.
- Configure billing thresholds and alerts using AWS/Firebase Console.

R11 PostGIS Geospatial Query Performance**Rare****Sev: High***Category: Technical***Impact**

Without proper spatial indexing, proximity queries against a large capsule dataset will exceed the 3-second API response SLA defined in the non-functional requirements. This directly degrades the core map view experience and makes real-time discovery feel unresponsive.

Prevention Measures

- Create a GIST spatial index on the capsule location column in PostgreSQL.
- Use ST_DWithin for radius-based proximity queries (optimized for GIST indexes).
- Cache nearby capsule lists client-side with a short TTL (30 seconds) to reduce repeated queries.
- Benchmark query performance with realistic data volumes (100K+ capsules) in the staging environment before launch.

4.4. Operational

R12 Inappropriate / Illegal User-Generated Content**Possible****Sev: High***Category: Operational***Impact**

Capsules containing explicit, hateful, or illegal content dropped in public spaces (schools, playgrounds, tourist sites) create significant legal liability and reputational damage. Without a moderation pipeline, the platform can be weaponized for harassment or illegal activity.

Prevention Measures

- Use AI Content Moderation upon capsule upload (e.g. Google's Vision SafeSearch or Amazon Web Services' Rekognition) to have AI automatically flag images that violate the companies policies.
- Have an in-app reporting feature to allow users to report inappropriate capsules.
- Include definitions of community standards and acceptable use within your Terms of Service prior to launching the product.
- Include a legal review of potential content liability in your plans prior to making the product available to the public.

R13	Capsule Spam / Low-Quality Content	Possible	Sev: Medium
<i>Category: Operational</i>			
Impact Users dropping large numbers of empty or trivial capsules to farm points clutter the map, degrade the discovery experience for genuine users, and inflate the database with low-value records.			
Prevention Measures • Use the existing 24-hour / same-coordinate rule to restrict how many capsules each user can drop per day. Use this at the database level. • There should be an ability for you to set a maximum number of capsules a user can drop in a single day. • The amount of points earned on a capsule should be weighted to the users capsule discovery rate. More valuable content will earn more. • Minimum content quality should be required for all text capsules. For example, the minimum characters a user has to write to create a text capsule and there cannot be only white space.			

4.5. Business

R14	Insufficient Critical Mass of Users	Possible	Sev: High
<i>Category: Business</i>			
Impact The discovery mechanic requires a sufficiently dense capsule network. In low-population areas or during early launch phases, users find no capsules and churn before experiencing the core value of the application. This creates a classic cold-start problem that can be fatal for a location-based social platform.			
Prevention Measures • Place team-created capsules throughout the target launch area. • Partner with universities as part of an initial test rollout to take advantage of high-density populations and users who are tech-savvy. • Create a 'capsule trail' feature that presents curated discovery paths to help new users find their first capsules. • Provide additional points and/or recognition to early adopters to encourage them to create content before there is a sufficient number of users to allow for the desired amount of discovery.			

R15	Firebase / Third-Party Service Outage	Rare	Sev: High
<i>Category: Business</i>			
Impact Downtime of Firebase Authentication, Firebase Cloud Messaging, or Google Maps API makes authentication and core features simultaneously unavailable for all users. Third-party SLA breaches are outside the development team's control but directly affect the perceived reliability of Memento.			
Prevention Measures			

- Implementing a "graceful degradation" strategy: cache local map tile images for offline use and queue notifications for Firebase Cloud Messaging to be retried upon successful reconnect.
- Design the JWT-based session so tokens remain valid during brief Firebase Authentication outages (no online validation for every request).
- Monitor third-party service status pages and set up automated alerts.
- Develop and document an Incident Response Runbook addressing each major dependency of Momento.

5. Risk Priority Matrix

The table below ranks all 15 risks by priority for implementation planning, ordered from most to least critical.

#	Vulnerability	Type	Severity	Priority
R01	GPS Spoofing / Location Forgery	Location Integrity	High	P1 – Critical
R02	IDOR on Capsule Media	Access Control	Critical	P1 – Critical
R03	Session Token Theft / JWT	Authentication	Critical	P1 – Critical
R05	Excessive Location Data Retention	Privacy / GDPR	Critical	P1 – Critical
R06	GDPR / Data Protection Non-Compliance	Legal/Regulatory	High	P2 – High
R07	Mass Assignment / SQL Injection	Input Validation	High	P2 – High
R11	PostGIS Geospatial Query Performance	Performance	High	P2 – High
R12	Inappropriate / Illegal UGC	Content Safety	High	P2 – High
R14	Insufficient Critical Mass of Users	Business Growth	High	P2 – High
R15	Firebase / Third-Party Service Outage	Resilience	High	P2 – High
R04	FCM Push Notification Leakage	Info Disclosure	Medium	P3 – Medium
R08	GPS Accuracy / Indoor Failure	UX / Technical	Medium	P3 – Medium
R09	Excessive Battery Drain from GPS	UX / Technical	Medium	P3 – Medium
R10	Cloud Storage Cost Overrun	Cost / Operations	Medium	P3 – Medium
R13	Capsule Spam / Low-Quality Content	Operational	Medium	P3 – Medium

6. Mitigation Roadmap

The following phased roadmap organizes mitigation activities across the development lifecycle. Phases are ordered by the stage at which the risk must be addressed.

Phase 1 — Pre-Development (Architecture Decisions)

These risks must be resolved through architectural design decisions before any code is written. Retrofitting these controls after development begins is significantly more costly.

- R02 – IDOR on Capsule Media: Design private storage buckets and signed URL architecture from day one.

- R03 – JWT / Session Security: Choose JWT library and configure validation strategy before implementing any API endpoints.
- R05 – Location Data Retention: Define the minimal data model for location storage at the database design stage.
- R06 – GDPR / DPIA: Conduct the DPIA and draft the privacy policy before any user-facing features are built.
- R07 – Mass Assignment / SQL Injection: Establish DTO patterns and ORM usage standards as project conventions from the start.

Phase 2 — Development Sprint (Build Alongside Core Features)

These mitigations must be implemented in parallel with the corresponding core features during development sprints.

- R01 – GPS Spoofing: Implement anomaly detection and server-side cross-validation in the Capsule Discovery Submodule.
- R04 – FCM Notification Hardening: Enforce opaque payloads and secret management from the first push notification implementation.
- R08 – GPS Accuracy / Proximity Radius: Implement configurable radius and fallback location modes before the first map view release.
- R09 – Battery Drain Optimization: Integrate significant-location-change API from the first implementation of background GPS.
- R11 – PostGIS Query Indexing: Create spatial indexes and benchmark against target data volumes during the database development sprint.

Phase 3 — Pre-Launch QA (Required for Public Beta)

These mitigations are required before the application is released to any public users.

- R10 – Cloud Storage Cost Controls: Implement and test file size limits, client-side compression, and billing alerts before public upload is enabled.
- R12 – Content Moderation Pipeline: Integrate and test the AI moderation service and in-app reporting flow before public launch.
- R13 – Anti-Spam / Rate Limiting: Enforce drop limits, duplicate coordinate constraint, and quality thresholds in pre-launch QA.

Phase 4 – Post-Launch Monitoring (Ongoing Operational Vigilance)

These risks require continuous monitoring and strategic responses that evolve with the platform's growth.

- R14 – User Critical Mass Strategy: Execute the campus launch strategy, seed capsules, and track discovery rate KPIs post-launch.
- R15 – Third-Party Service Resilience: Monitor Firebase / Google Maps SLA dashboards, test graceful degradation quarterly, and maintain the incident response runbook.

7. Conclusion

The 15 risks identified in this plan represent the most significant threats to the Momento application across its security, legal, technical, operational, and business dimensions. The most severe risks – GPS Spoofing, IDOR on Capsule Media, Session Token Theft, and Excessive Location Data Retention – are rated Critical and must be fully addressed before any public release.

Six additional risks rated High — including GDPR compliance, SQL Injection protection, PostGIS performance, content moderation, user critical mass, and service resilience – must be addressed before or immediately following public launch.

The remaining five Medium risks, notably GPS accuracy degradation and excessive battery drain, are rated Very Likely or Possible and must be handled during core development to prevent early user churn.

All mitigation measures described in this plan are achievable within the specified technology stack (React Native, Java/Spring Boot, PostgreSQL/PostGIS, Firebase, AWS S3) and are aligned with OWASP Top 10 guidelines, GDPR requirements, and Firebase security best practices. No significant architectural changes are required beyond those already implied by good engineering practice.

Riga 2026